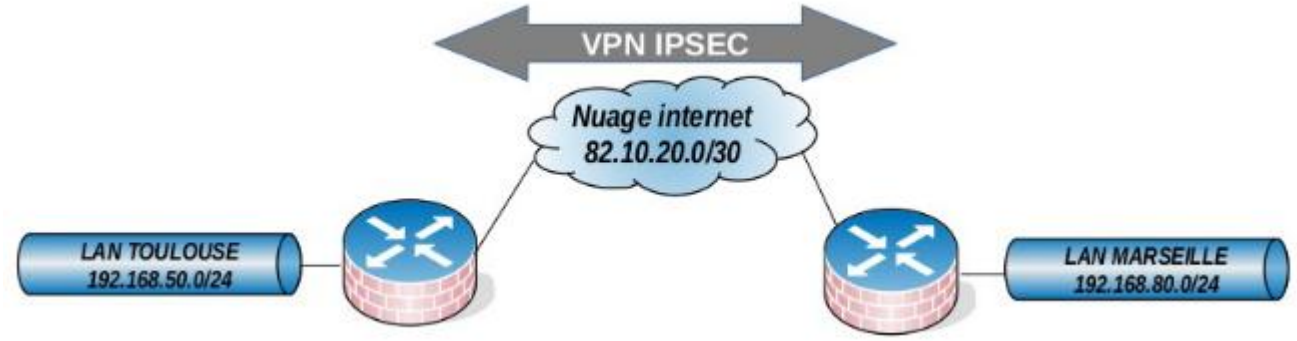
NOM Prénom : Ethan Georget
BTS SIO SISR - Bloc 2
Compte-Rendu : Déploiement de tunnels VPN IPsec (SNS) et SSL (pfSense)

DOSSIER TECHNIQUE : INTERCONNEXION ET ACCÈS DISTANT SÉCURISÉ

1. Interconnexion de sites via VPN IPsec (Stormshield)

Ce volet traite de l'établissement d'un tunnel sécurisé entre les sites de Toulouse et Marseille. L'infrastructure utilise deux firewalls Stormshield SNS4. Le routage statique a été configuré pour pointer vers les passerelles distantes simulant le transit via le nuage internet.



Préparation de l'environnement Stormshield Avant de configurer les tunnels, j'ai préparé les instances virtuelles des firewalls Stormshield SNS. J'ai configuré les interfaces réseau sous Virtualbox en créant le segment « NUAGE-OUT » pour simuler le transit internet entre les sites, ainsi que les réseaux locaux « LAN-TOULOUSE » et « LAN-MARSEILLE ».

INTERFACE	RÉSEAU VIRTUALBOX	NOM DU RÉSEAU	ADRESSAGE IP
1ère interface	Réseau interne	NUAGE-OUT	82.10.20.1/30
2ème interface	Réseau interne	LAN-TOULOUSE	192.168.50.254/24
3ème interface	Réseau interne	DMZ-TOULOUSE	172.16.10.254/24

FIREWALL-MARSEILLE

INTERFACE	RÉSEAU VIRTUALBOX	NOM DU RÉSEAU	ADRESSAGE IP
1ère interface	Réseau interne	NUAGE-OUT	82.10.20.2/30
2ème interface	Réseau interne	LAN-MARSEILLE	192.168.80.254
3ème interface	Réseau interne	DMZ-MARSEILLE	172.16.20.254/24

CLIENT-TOULOUSE

INTERFACE	RÉSEAU VIRTUALBOX	NOM DU RÉSEAU	ADRESSAGE IP
1ère interface	Réseau interne	LAN-TOULOUSE	192.168.50.1/24

CLIENT-MARSEILLE

INTERFACE	RÉSEAU VIRTUALBOX	NOM DU RÉSEAU	ADRESSAGE IP
1ère interface	Réseau interne	LAN-MARSEILLE	192.168.80.1/24

1.1 Tunnel par clé partagée et politique de filtrage

Initialement, le tunnel a été monté via une authentification PSK (Pre-Shared Key). Une attention particulière a été portée aux règles de filtrage : les flux doivent explicitement être autorisés 'via Tunnel VPN IPsec' pour permettre le transit inter-LAN.

Contrôle des flux inter-sites Pour sécuriser la liaison, j'ai créé des règles de filtrage spécifiques sur chaque boîtier SNS. J'ai veillé à ce que les flux entre les réseaux de Toulouse et Marseille soient explicitement autorisés uniquement lorsqu'ils transitent par le tunnel VPN IPsec, interdisant ainsi toute communication non chiffrée.

POLITIQUE DE CHIFFREMENT - TUNNELS | CORRESPONDANTS | IDENTIFICATION | PROFILS DE CHIFFREMENT

(1) IPsec 01 | Activer cette politique | Editer

SITE À SITE (GATEWAY-GATEWAY) | ANONYME - UTILISATEURS NOMADES

Texte recherché | + Ajouter | Supprimer | Monter | Descendre | Couper | Copier | Coller

Ligne	Etat		Réseau local	Correspondant	Réseau distant	Profil de chiffrement	Keepalive	Commentaire
1	on		Network_in	Site_FW-MARSEILLE	LAN-MARSEILLE	StrongEncryption	0	

FILTRAGE | NAT

Rechercher... | + Nouvelle règle | Supprimer | Couper | Copier | Coller | Chercher dans les logs | Chercher dans la supervision

		État	Action	Source	Destination	Port dest.	Protocole	Inspection de sécurité
Remote Management: Go to System - Configuration to setup the web administration application access (contient 2 règles, de 1 à 2)								
1		on	passer	Any	firewall_all	firewall_srv https		IPS
2		on	passer	Any	firewall_all	Any	icmp (requête Ech	IPS
Politique VPN (contient 2 règles, de 3 à 4)								
3		on	passer	Network_in	LAN-MARSEILLE	Any		IPS
4		on	passer	LAN-MARSEILLE via Tunnel VPN IPSec	Network_in	Any		IPS
Séparateur - regroupement de règles (contient 1 règles, de 5 à 5)								
5		on	bloquer	Any	Any	Any		IPS

1.2 Migration vers une authentification Certificats (PKI)

Pour augmenter le niveau de sécurité, une PKI a été déployée. L'autorité racine (CA) créée à Toulouse a servi à signer les certificats serveurs des deux boîtiers. L'échange des certificats via SCP et leur importation au format P12 ont permis de valider l'identité des pairs sans utiliser de mot de passe statique.

PROPRIÉTÉS DE L'AUTORITÉ DE CERTIFICATION

Nom (CN): fw-toulouse

Identifiant: fw-toulouse

Attributs de l'autorité

Organisation (O): mlif

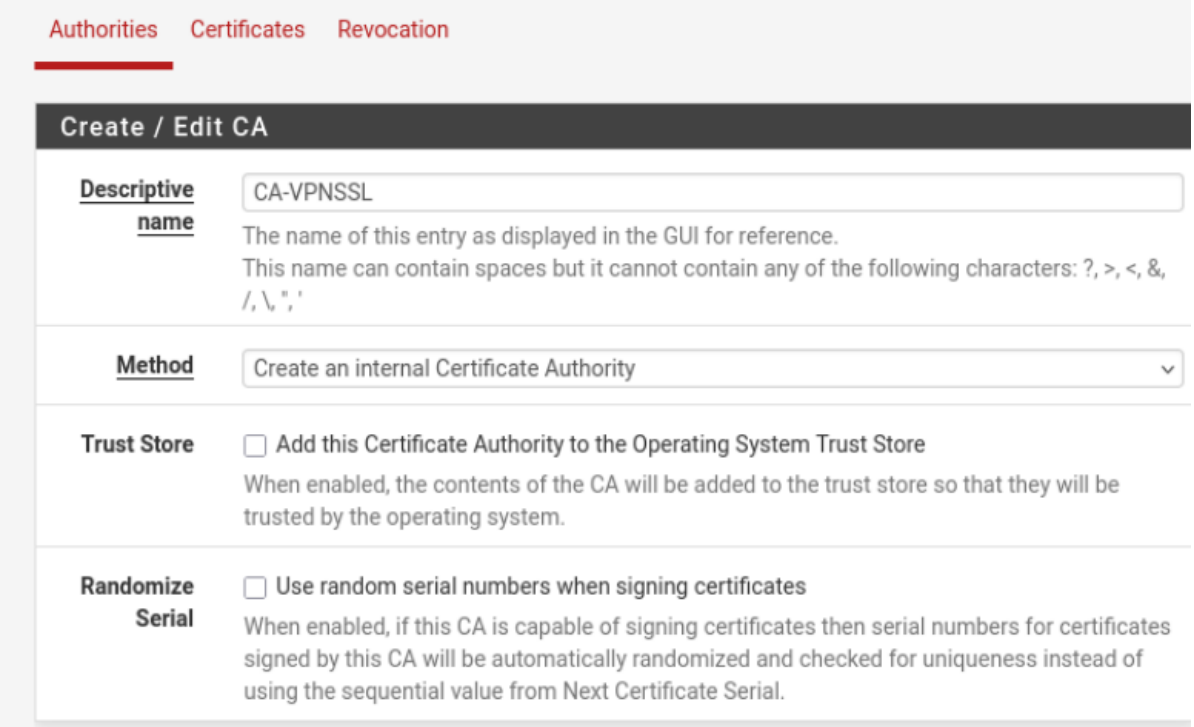
Unité d'organisation (OU): mlif

Ville (L): toulouse

État (ST): occitanie

Pays (C): France

Gestion et importation des certificats PKI Afin de supprimer l'utilisation de clés statiques, j'ai déployé une autorité de certification (CA) racine. J'ai ensuite généré et importé les certificats au format P12 sur chaque boîtier. Cette méthode permet une identification forte des pairs basée sur des certificats signés, renforçant considérablement la sécurité du tunnel.



2. Accès distant via VPN SSL (pfSense OpenVPN)

L'objectif est de permettre à un client 'Nomade' de rejoindre les ressources de la MLIF (réseau 192.168.100.0/24) en transitant par une interface WAN Bridge.

2.1 Infrastructure de confiance (CA et Certificats)

Une CA dédiée 'CA-VPNSSL' a été mise en œuvre sur pfSense. Nous avons généré un certificat serveur (CERT-SRV-VPN) et un certificat utilisateur (CERT-JOHN-DOE). Les paramètres de sécurité utilisent des clés RSA 2048 bits et l'algorithme de hachage SHA256.

ACs | Certificats | Révocation de certificat

Créer / Modifier l'AC

Nom descriptif	CA-VPNSSL
Méthode	Créer une autorité de certification interne

Autorité de certification Interne

Longueur de la clé (bits)	2048
Algorithme de hachage	sha256 REMARQUE: Il est recommandé d'utiliser un algorithme plus fort que SHA1 lorsque cela est possible.
Durée de vie (jours)	3650
Nom commun	CA-VPNSSL

Les composantes suivantes de l'autorité de certification sont facultatives et peuvent être laissées vides.

Code du pays	FR
État ou province	IDF
Ville	Paris
Organisation	MLIF

Certificat Interne

Autorité de certification	CA-VPNSSL
Longueur de la clé	2048
Algorithme de hachage	sha256 REMARQUE: Il est recommandé d'utiliser un algorithme plus fort que SHA1 lorsque cela est possible.
Durée de vie (jours)	3650
Nom commun	b2b.mlif.local

2.2 Paramétrage avancé du serveur OpenVPN

Le serveur est configuré en mode 'Accès à distance (SSL/TLS)' sur le port UDP 1194. Le tunnel utilise l'interface 'tun' (Layer 3). Pour garantir la confidentialité, le paramètre Diffie-Hellman (DH) est fixé à 2048 bits.

Informations Générales

Désactivé	[ ] Désactiver ce serveur Définissez cette option pour désactiver ce serveur sans le retirer de la liste.
Mode serveur	Accès à distance (SSL/TLS)
Protocole	UDP on IPv4 only
Mode dispositif	tun - Layer 3 Tunnel Mode Le mode "tun" porte IPv4 et IPv6 (couche OSI 3) et est le mode le plus courant et compatible sur toutes les plates-formes. Le mode "tap" est capable de transporter 802.3 (couche OSI 2.)
Interface	WAN L'interface ou l'adresse IP virtuelle où OpenVPN recevra les connexions des clients
Port local	1194 Le port utilisé par OpenVPN pour recevoir des connexions client.
Description	VPN-NOMADE-MLIF Une description peut être saisie ici à des fins de référence administrative (non analysée).

Paramètres cryptographiques

Configuration TLS	[ ] Utiliser une clé TLS Une clé TLS améliore la sécurité d'une connexion OpenVPN en demandant aux deux parties d'avoir une clé commune avant qu'un pair puisse effectuer une négociation TLS. Cette couche d'authentification HMAC permet de transférer les paquets de canal de contrôle sans que la clé appropriée soit supprimée, protégeant les pairs contre les attaques ou les connexions non autorisées. La clé TLS n'a aucun effet sur les données du tunnel.
TLS keydir direction	Use default direction The TLS Key Direction must be set to complementary values on the client and server. For example, if the server is set to 0, the client must be set to 1. Both may be set to omit the direction, in which case the TLS Key will be used bidirectionally.
Autorité de certification du pair	CA-VPNSSL
Liste des Certificats de Révocation de pairs.	No Certificate Revocation Lists defined. One may be created here: System > Cert. Manager
Certificat du serveur	CERT-SRV-VPN (Serveur : Oui, CA : CA-VPNSSL, En cours d'utilisatic
Longueur du paramètre *DH	2048 bit Ensemble de paramètres Diffie-Hellman (DH) utilisé pour l'échange de clés.

Le serveur 'pousse' (push) la route vers le LAN local (192.168.100.0/24) ainsi que les paramètres DNS (domaine mlif.local et DNS 8.8.8.8). Nous avons activé le mécanisme NCP (Negotiable Crypto Parameters) avec les algorithmes AES-128-GCM et AES-256-CBC pour assurer la compatibilité avec divers clients.

Rediriger la passerelle IPv4	☐ Force all client-generated IPv4 traffic through the tunnel.
Rediriger la passerelle IPv6	☐ Force all client-generated IPv6 traffic through the tunnel.
Réseau(x) local/locaux IPv4	192.168.100.0/24,127.0.0.1/32 Les réseaux IPv4 qui seront accessibles à partir du point d'extrémité distant. Exprimé sous la forme d'une liste séparée par des virgules d'une ou plusieurs gammes CIDR. Cela peut être laissé vide si vous n'ajoutez pas d'itinéraire au réseau local via ce tunnel sur la machine distante. Ceci est généralement défini sur le réseau LAN.
Réseau(x) local/locaux IPv6	Les réseaux IPv6 qui seront accessibles depuis le point d'extrémité distant. Exprimé sous la forme d'une liste séparée par des virgules d'un ou plusieurs IP / PREFIX. Cela peut être laissé vide si vous n'ajoutez pas d'itinéraire au réseau local via ce tunnel sur la machine distante. Ceci est généralement défini sur le réseau LAN.
Connexions simultanées	5 Spécifier le nombre maximum de clients autorisés à se connecter en même temps à ce serveur.
Compression	Ne pas préciser de préférence (Utilisation de OpenVPN par défaut) Compresser les paquets de tunnel en utilisant l'algorithme LZO. La compression peut potentiellement augmenter le débit mais peut permettre à un attaquant d'extraire des secrets s'il peut contrôler le texte en clair compressé traversant le VPN (par exemple HTTP). Avant d'activer la compression, consultez les informations sur les attaques VORACLE, CRIME, TIME et BREACH contre TLS pour décider si le cas d'usage spécifique à ce VPN est vulnérable à l'attaque.

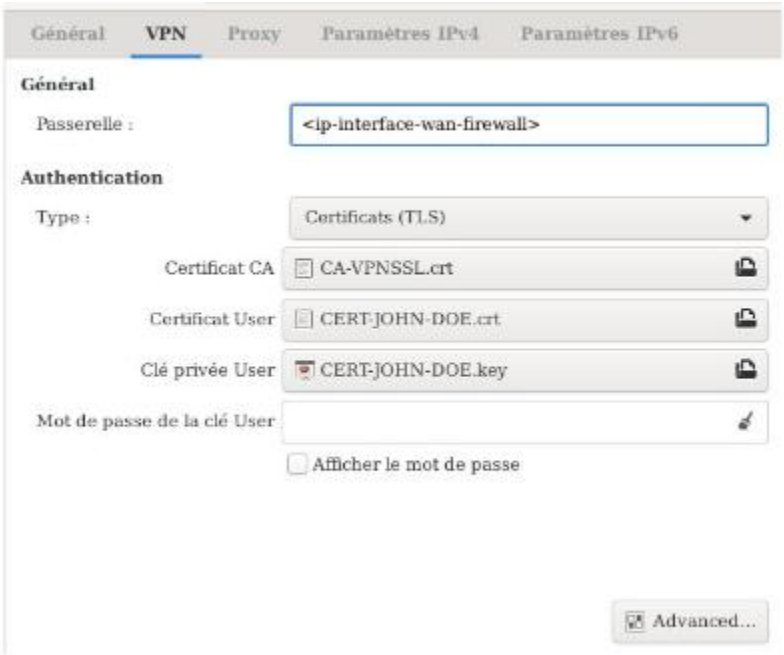
Courbe ECDH	Utiliser les valeurs par défaut La courbe elliptique à utiliser pour l'échange de clés. La courbe du certificat du serveur est utilisée par défaut lorsque le serveur utilise un certificat ECDSA. Sinon, secp384r1 est utilisé comme un repli.
Algorithme de chiffrement	AES-256-CBC (256 bit key, 128 bit block) L'algorithme de chiffrement utilisé pour les paquets du canal de données lorsque le support de paramètre cryptographique négociable (NCP) n'est pas disponible.
Activer NCP	☐ Activer les paramètres cryptographiques négociables Cochez cette option pour permettre aux clients et aux serveurs OpenVPN de négocier un ensemble compatible d'algorithmes de chiffrement cryptographiques acceptables à partir de ceux sélectionnés dans la liste des Algorithmes NCP ci-dessous.
Algorithmes NCP	AES-128-CBC (128 bit key, 128 bit block) AES-128-CFB (128 bit key, 128 bit block) AES-128-CFB1 (128 bit key, 128 bit block) AES-128-CFB8 (128 bit key, 128 bit block) AES-128-GCM (128 bit key, 128 bit block) AES-128-OFB (128 bit key, 128 bit block) AES-192-CBC (192 bit key, 128 bit block) AES-192-CFB (192 bit key, 128 bit block) AES-192-CFB1 (192 bit key, 128 bit block) AES-192-CFB8 (192 bit key, 128 bit block) Algorithmes de chiffrement NCP disponibles Cliquez pour ajouter ou supprimer un algorithme de la liste AES-128-GCM AES-128-CBC AES-256-CBC Algorithmes de chiffrement NCP autorisés. Cliquez sur un nom d'algorithme pour le supprimer de la liste L'ordre des Algorithmes de chiffrement NCP sélectionnés est respecté par OpenVPN.

Paramètres clients avancés

Domaine DNS par défaut	☑ Renseigner un nom de domaine par défaut aux clients.
Domaine DNS par défaut	mlif.local
Activer le Serveur DNS	☑ Fournisser une liste de serveur DNS pour les clients. Les adresses peuvent être en IPv4 ou IPv6.
Serveur DNS 1	8.8.8.8

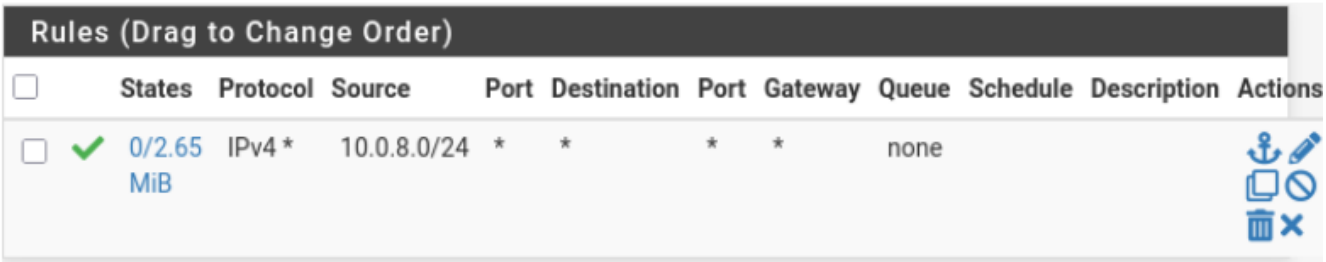
2.3 Configuration du client Nomade et Sécurité

Côté client, le profil de connexion doit impérativement correspondre aux réglages serveur : certificat CA, certificat utilisateur et clé privée. L'authentification HMAC (SHA-256) est activée pour protéger le canal de contrôle.



Sécurisation du canal de contrôle (HMAC)

Côté client, j'ai configuré le profil de connexion en incluant le certificat CA ainsi que les clés de l'utilisateur. J'ai également activé l'authentification HMAC avec l'algorithme SHA-256 pour protéger les messages de contrôle du tunnel contre les attaques par injection ou modification de trames.



3 Validation de l'accès aux serveurs internes

Le succès de l'interconnexion a été confirmé par l'apparition de l'icône du cadenas dans le gestionnaire de connexions client. J'ai validé la portée du tunnel en effectuant un test de communication SSH vers une machine située dans la zone serveur de la MLIF, prouvant que le VPN SSL offre un accès distant opérationnel et sécurisé.

```
test@client-mlif:~/Téléchargements$ scp CERT-JOHN-DOE.key test@172.17.123.12:/home/test
test@172.17.123.12's password:
CERT-JOHN-DOE.key                                     100% 1704   554.8KB/s   00:00
test@client-mlif:~/Téléchargements$ scp CERT-JOHN-DOE.crt test@172.17.123.12:/home/test
test@172.17.123.12's password:
CERT-JOHN-DOE.crt                                     100% 1623     2.1MB/s   00:00
```

4. Validation finale et test de connexion

Le test de fonctionnement a été validé par l'apparition du cadenas dans le gestionnaire de connexions du client. L'accès aux ressources internes de la zone serveur de la MLIF a été confirmé par un test de communication (Ping/SSH) depuis le poste nomade.

```
root@archa:/home/test# ping 192.168.50.20
PING 192.168.50.20 (192.168.50.20) 56(84) bytes of data.
64 bytes from 192.168.50.20: icmp_seq=8 ttl=64 time=0.510 ms
64 bytes from 192.168.50.20: icmp_seq=9 ttl=64 time=0.248 ms
64 bytes from 192.168.50.20: icmp_seq=10 ttl=64 time=0.366 ms
```

4.1 Conclusion technique

Ce laboratoire a permis de mettre en œuvre deux technologies VPN complémentaires. L'IPsec assure une liaison permanente robuste entre sites fixes, tandis que le VPN SSL offre une solution d'accès sécurisé flexible pour les collaborateurs distants. La gestion rigoureuse de la PKI reste l'élément central de la sécurité de ces infrastructures.